

Cybersecurity Testing Checklist

Document ID: GKB-SEC-TEST-003

Version: 1.0

Scope: General Knowledge Base

Intended use: reusable security test planning checklist

Owner: Cybersecurity Validation Team

1. Purpose

This checklist helps test engineers plan and review technical cybersecurity tests for applications, APIs, connected devices, and industrial systems.

It is inspired by NIST SP 800-115, which describes planning, conducting, analyzing, and reporting technical information security tests and assessments.

2. Security Test Planning Principles

Security testing should be:

- authorized;
- scoped;
- risk-based;
- repeatable;
- evidence-driven;
- safe for the target environment;
- followed by remediation tracking.

Security tests must not be executed on production systems without explicit authorization.

3. Planning Checklist

Before testing, confirm:

- written authorization exists;
- target systems are identified;
- excluded systems are listed;
- testing windows are approved;
- accounts and roles are available;
- backup and rollback plans exist;
- logging is enabled;
- evidence storage is prepared;
- responsible contacts are known;
- severity definitions are agreed.

4. Authentication Tests

SEC-TC-AUTH-001 Unauthenticated Access

Objective:

- verify protected endpoints reject unauthenticated requests.

Steps:

1. Send requests without credentials.
2. Send requests with malformed tokens.
3. Send requests with expired tokens.
4. Send requests with revoked tokens.

Expected results:

- protected endpoints return 401 or equivalent;
- no protected data is returned;
- failures are logged without exposing secrets.

SEC-TC-AUTH-002 Session Expiration

Objective:

- verify inactive sessions expire according to policy.

Expected results:

- inactive session is rejected after timeout;
- refresh token rules are enforced;
- user must authenticate again when required.

SEC-TC-AUTH-003 Failed Login Lockout

Objective:

- verify brute-force protection.

Expected results:

- account is locked or throttled after configured failed attempts;
- failed attempts are audited;
- error messages do not reveal whether the email exists.

5. Authorization Tests

SEC-TC-AZ-001 Role Permission Matrix

Create a matrix of roles and privileged actions.

For each role:

- attempt allowed actions;
- attempt forbidden actions;
- verify expected status codes;
- verify audit events.

Example matrix:

Action	Viewer	Editor	Admin
Read project	Allowed	Allowed	Allowed
Upload document	Denied	Allowed	Allowed
Delete project	Denied	Denied	Allowed
Manage users	Denied	Denied	Allowed

SEC-TC-AZ-002 Horizontal Access Control

Objective:

- verify users cannot access another user's project or tenant.

Steps:

1. Create two projects owned by different users.
2. Authenticate as user A.
3. Attempt to read or modify user B's project.

Expected result:

- access is denied and no object metadata is leaked.

SEC-TC-AZ-003 Privilege Escalation

Objective:

- verify users cannot assign themselves higher privileges.

Expected result:

- role changes require an authorized administrator.

6. Input and API Security Tests

Test the following:

- invalid JSON;
- missing required fields;
- oversized payloads;
- unexpected data types;
- path traversal attempts;
- SQL injection patterns;
- command injection patterns;
- cross-site scripting payloads;
- file upload extension bypass;
- duplicate identifiers;
- race conditions on create/update/delete operations.

Expected results:

- invalid input is rejected;
- errors are safe and non-verbose;
- no stack traces are exposed;
- logs contain enough diagnostic detail without secrets.

7. Secrets Handling Tests

SEC-TC-SECRET-001 Response Redaction

Verify that APIs never return:

- passwords;
- API tokens;
- private keys;
- refresh tokens;
- cloud credentials;
- internal signing secrets.

SEC-TC-SECRET-002 Diagnostic Bundle Redaction

Seed known secret patterns in:

- environment variables;
- nested JSON logs;
- HTTP headers;
- configuration files;
- adapter debug output.

Expected result:

- exported diagnostic bundles redact all known secrets.

SEC-TC-SECRET-003 Log Redaction

Verify that application logs do not store raw secrets.

8. Transport Security Tests

Verify:

- TLS is enabled for remote access;
- weak protocol versions are disabled;
- certificate chain validation works;
- hostname validation is enforced;
- plaintext HTTP is disabled or redirected according to policy;
- telemetry is not sent when cloud certificate validation fails.

9. Audit Logging Tests

Security-relevant actions should produce audit events:

- login success;
- login failure;
- logout;
- role change;
- permission denial;
- privileged configuration update;
- token creation;
- token revocation;
- export operation;
- support access grant;
- support access revocation.

Each audit event should include:

- actor;
- action;
- target;
- timestamp;
- result;
- source IP or client identifier;
- correlation ID if available.

10. Vulnerability Assessment Checklist

Review:

- dependency vulnerabilities;
- open ports;
- default credentials;
- insecure headers;
- exposed debug endpoints;
- excessive permissions;
- outdated cryptographic algorithms;
- unencrypted sensitive files;
- insecure temporary files;
- container image vulnerabilities.

11. Penetration Test Boundaries

If penetration testing is included, define:

- allowed techniques;
- prohibited techniques;
- rate limits;
- social engineering policy;
- data handling requirements;
- stop conditions;
- reporting timeline.

12. Reporting Template

Each finding should include:

- finding ID;
- title;
- severity;
- affected component;
- description;
- reproduction steps;
- impact;
- evidence;
- recommended remediation;
- owner;
- target fix date;
- retest result.

13. Severity Guidance

Critical:

- unauthorized administrative access;
- secret disclosure;
- remote code execution;
- persistent access bypass.

High:

- privilege escalation;
- cross-tenant data exposure;
- missing authentication on sensitive endpoint;
- audit bypass for privileged actions.

Medium:

- verbose errors exposing internal details;
- weak password policy;
- missing security header;
- insufficient rate limiting.

Low:

- minor information disclosure;
- security documentation gap;
- non-sensitive banner leakage.

14. References

- NIST SP 800-115 Technical Guide to Information Security Testing and Assessment.
- Common professional practice for API security, RBAC testing, secrets handling, and audit testing.